

■■ CHECKLIST DE SEGURIDAD WEB A MEJORAR

Proyecto: Plataforma Web SEIN | **Enfoque:** Blindaje y Buenas Prácticas

Este checklist detalla las acciones técnicas de seguridad necesarias para proteger los datos del negocio, la información de los clientes y garantizar la estabilidad del sitio web.

1. NIVEL CRÍTICO: PROTECCIÓN DE DATOS Y RESPALDOS

- ☐ **Retiro inmediato de respaldos (.zip) públicos:** Mover los archivos *public_html.zip* y *hostinger_gamma_automotriz.zip* (~12 GB) fuera de la raíz web. *Evita la descarga no autorizada de bases de datos y accesos.*
- ☐ **Bloqueo de exploración de directorios:** Desactivar listado de carpetas (*Directory Browsing / Options -Indexes*) para no exponer la estructura de archivos.
- ☐ **Eliminación de usuarios y rutas de prueba:** Purgar rutas como */sample-page/*, */hello-world/* y la enumeración de usuarios en */author/*.

2. NIVEL SERVIDOR, ALOJAMIENTO Y DOMINIO

- ☐ **Certificado SSL / HTTPS Obligatorio:** Forzar redirección de HTTP a HTTPS con cifrado seguro y soporte HSTS.
- ☐ **Cabeceras de Seguridad HTTP (Security Headers):**
 - *X-Frame-Options (SAMEORIGIN):* Previene que terceros incrusten la web en marcos falsos (Clickjacking).
 - *X-Content-Type-Options (nosniff):* Bloquea ataques de inyección por confusión de tipo MIME.
 - *Referrer-Policy (strict-origin-when-cross-origin):* Protege datos en enlaces salientes.
- ☐ **Protección de archivos de configuración:** Bloqueo web total a extensiones sensibles (*.sql*, *.env*, *.git*, *.log*, *.conf*).

3. NIVEL CÓDIGO, ENLACES Y PRIVACIDAD

- ☐ **Limpieza de nonces y scripts obsoletos:** Retirar llamadas a endpoints no activos de WordPress para eliminar errores en consola.
- ☐ **Enlaces externos seguros:** Validar que todos los botones a WhatsApp o redes sociales incluyan *rel='noopener noreferrer'*.
- ☐ **Cumplimiento y Privacidad:** Actualizar la página de *Políticas de Privacidad* para informar el manejo de datos de contacto.
- ☐ **Transacciones Seguras (PCI-DSS):** Delegar 100% de pagos electrónicos a pasarelas certificadas sin almacenar datos bancarios en el servidor.

Prioridad de Implementación: Los puntos del Nivel 1 deben resolverse antes de cualquier despliegue. Los Niveles 2 y 3 se configuran durante la publicación en el servidor final.